Practical Vulnerability Assessment for GRC Professionals

Student Name: Nolusindiso Sonjani
Student Number: C112617560
Course: GRC102
Lab: Practical Vulnerability Assessment
Target IP: 192.168.245.129
Attacker IP (Kali): 192.168.245.128
Date: 23 October 2026

1. Introduction

The purpose of this assessment was to perform a vulnerability assessment against the Metasploitable test system. The assessment included host discovery, service enumeration, vulnerability identification, risk analysis, and compliance mapping. The findings were evaluated from a Governance, Risk and Compliance (GRC) perspective to determine business impact and regulatory implications.

2. Network Discovery

Command Used

Shell
ping -c 4 192.168.245.129

Result

The target host responded successfully to ICMP requests, confirming that the system was active and reachable on the network.

GRC Context

Asset identification is essential for maintaining an accurate asset inventory and supports NIST CSF ID.AM-1 and CIS Control 1 requirements. Organizations cannot protect assets that have not been identified.

3. Port and Service Enumeration

Command Used

Shell
nmap -sV -sC -O -p- -oA initial_scan 192.168.245.129

HTML Report Conversion

Shell
xsltproc -o initial_scan_report.html /usr/share/nmap/nmap.xsl initial_scan.xml

Notable Open Ports

Port	Service	Observation
21	FTP	vsFTPd 2.3.4 detected
22	SSH	Remote access service
23	Telnet	Unencrypted remote access
25	SMTP	Mail service detected
53	DNS	Domain name service
80	HTTP	Web application server
111	RPC	Remote procedure call service
139	NetBIOS	Windows file sharing
445	SMB	SMB service exposed
3306	MySQL	Database service
5432	PostgreSQL	Database service

Compliance Mapping

- NIST CSF ID.AM-1 Asset identification and inventory
- NIST CSF PR.DS-2: Production of data in transit
- CIS Control 7: Continous vulnerability management
- CIS Control 9: Limitation and management of network services
- PCI DSS Requirement 6: Secure systems and applications

4. Web Application Assessment

Command Used

Shell
nikto -h http://192.168.245.129 -o nikto_scan.txt

Findings

- Default web pages detected.
- Potential directory listing exposure.
- Outdated software versions.
- Information leakage through HTTP headers.
- Development applications accessible through the browser.

5. Nuclei Vulnerability Scan

Web Scan

Shell
nuclei -u http://192.168.245.129 -o nuclei_web_scan.txt

Full Host Scan

Shell
nuclei -target 192.168.245.129 -o nuclei_full_scan.txt

Findings

Potential vulnerabilities identified include:

- Weak authentication mechanisms
- Known vulnerable software versions
- Exposed management services
- Potential CVE-related vulnerabilities

6. Risk Assessment Table

Finding	Affected Service	CVE/Reference	Risk	Compliance Violation	Business Impact
Weak Default Credentials	SSH, FTP	N/A	High	CIS 5.2, NIST PR.AC-1	Unauthorized access
vsFTPd 2.3.4 Backdoor	FTP	CVE-2011-2523	High	CIS 7.1	Complete system compromise
Unencrypted Telnet	Telnet	N/A	High	NIST PR.DS-2	Credential theft
Open SMB Shares	SMB	Multiple	Medium	CIS 4	Unauthorized file access
Outdated Web Server	HTTP	Various CVEs	High	PCI DSS 6	Web server compromise
Exposed Database Services	MySQL/PostgreSQL	Various CVEs	High	CIS 9	Data theft
Information Disclosure	HTTP Headers	N/A	Low	CIS 13	Reconnaissance assistance
Excessive Open Ports	Multiple	N/A	Medium	CIS 9	Increased attack surface

7. Executive Summary

To: IT Management
From: GRC Audit Team
Date: 23 October 2026
Subject: High-Risk Findings on Development Server "Metasploitable"

Executive Summary

A vulnerability assessment was conducted on the development server identified as Metasploitable. The assessment revealed multiple critical and high-risk vulnerabilities that could allow unauthorized access, system compromise, credential theft, and exposure of sensitive organizational information.

Several services were found running outdated software versions, including the vulnerable vsFTPd 2.3.4 FTP service, which contains a publicly known backdoor vulnerability. In addition, insecure services such as Telnet were enabled, exposing user credentials in plain text across the network.

The server does not comply with several security best practices outlined in CIS Controls and the NIST Cybersecurity Framework. Immediate remediation is recommended to reduce organizational risk.

Key Findings

Critical Risk: Remote System Compromise

The FTP service is running vsFTPd 2.3.4, which is vulnerable to CVE-2011-2523. Successful exploitation could permit unauthorized remote access and full control of the system.

High Risk: Credential Exposure

Telnet and FTP services transmit usernames and passwords in plain text. Attackers monitoring network traffic could capture credentials and gain unauthorized access.

High Risk: Weak Authentication

Default or weak credentials may be present on exposed services, significantly increasing the likelihood of unauthorized system access.

Medium Risk: Excessive Service Exposure

Numerous network services are accessible externally, increasing the attack surface and creating additional opportunities for attackers.

Recommendations

Immediate Actions

1. Isolate the server from production or sensitive networks.
2. Disable Telnet and other unnecessary services.
3. Update or replace vulnerable software versions.
4. Change all default credentials immediately.

Security Hardening

1. Implement strong password policies.
2. Restrict access through firewall rules.
3. Conduct regular vulnerability assessments.
4. Apply security baselines aligned to CIS Controls.

Process Improvements

1. Establish patch management procedures.
2. Perform regular compliance reviews.
3. Maintain an up-to-date asset inventory.

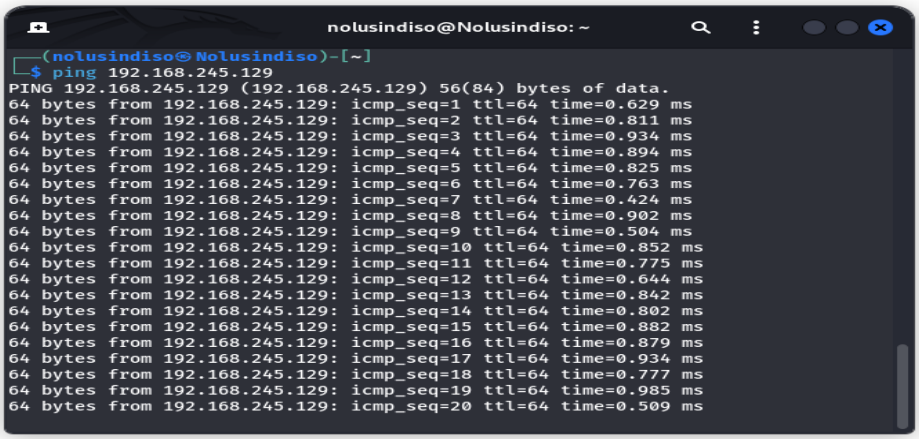
4. Implement secure system deployment standards.

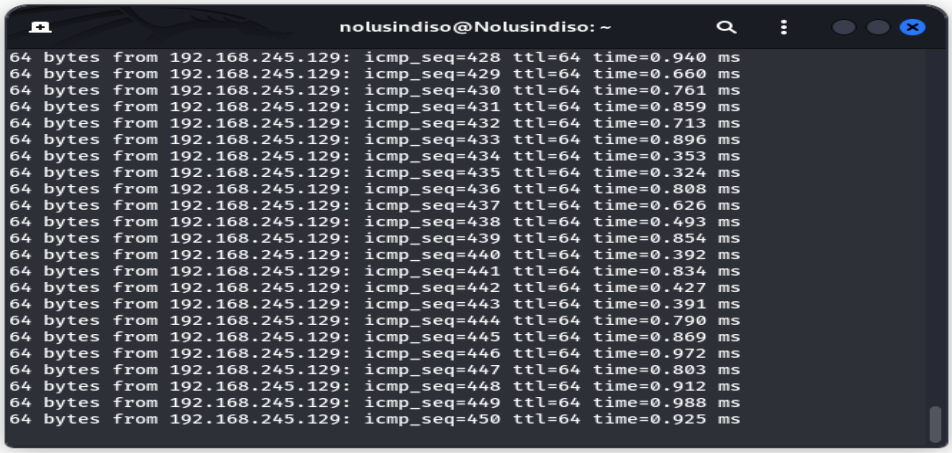
8. Conclusion

The vulnerability assessment identified several critical weaknesses that significantly increase the risk of unauthorized access and system compromise. The most serious findings include the vulnerable vsFTPd 2.3.4 service, the use of Telnet, and weak authentication controls. Prompt remediation and adherence to established security frameworks such as NIST CSF and CIS Controls will substantially improve the organization's security posture.

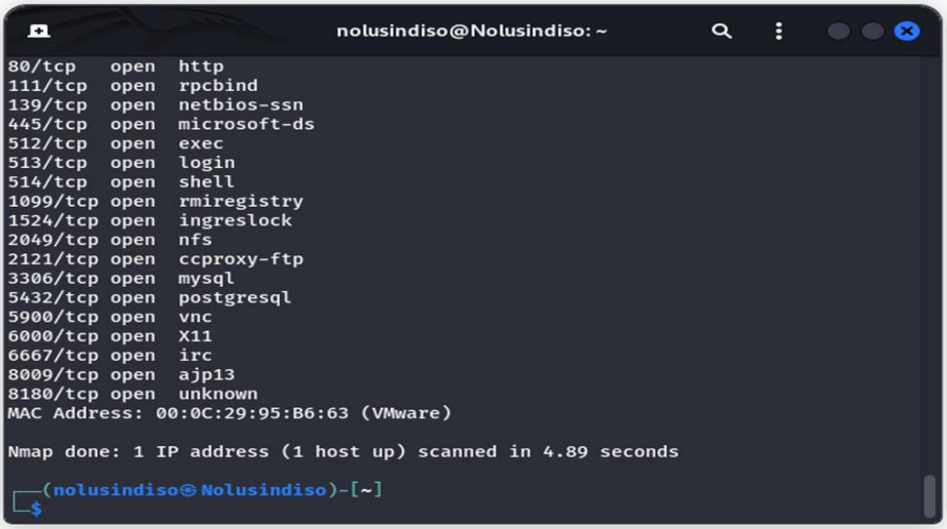
Screenshots to Attach

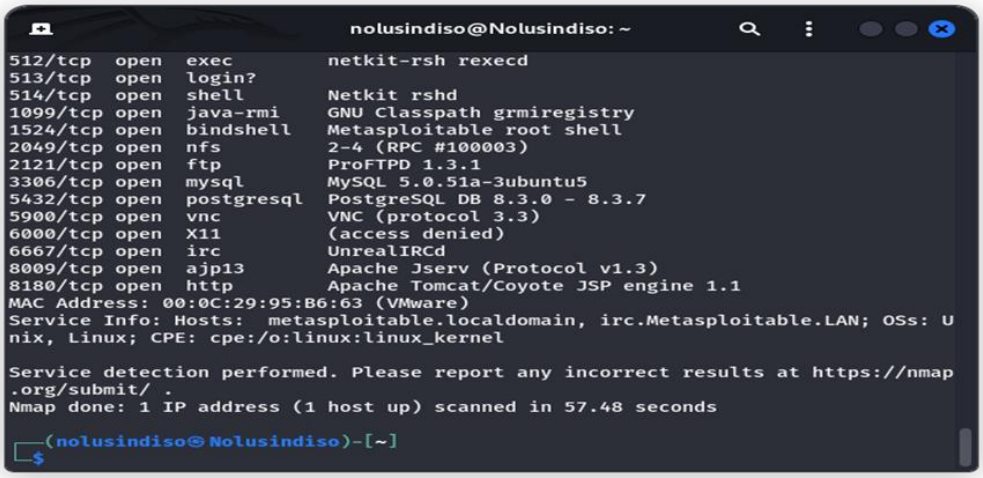
1. Ping results



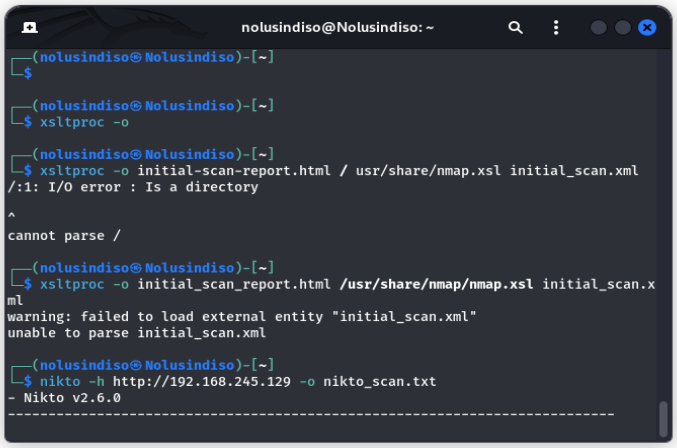


2. Nmap scan results





3. Nikto scan output



4. Nuclei scan output

